

SecCore Essentials - Backup Security

 seccore.at/blog/backup-security

Benjamin Floriani, Patrick Pongratz

September 29, 2025



Summary

This SecCore Essential is about securely creating, handling and storing backups. It is considered implemented if the following conditions are met:

- Backups are replicated to at least one off-site location
- Important file shares are regularly backed up or snapshotted (at least once a day).
- Backup servers are isolated from the production environment:
 - Not joined to the Active Directory domain
 - Isolated via [Network Segmentation](#)
 - Not on a VM-Hypervisor that is also used for production VMs
- Different administrative users are used for configuring backups
- Backups are regularly tested to ensure restore integrity

Introduction

Backups and snapshots are important mechanisms for disaster recovery. Malware infection, power outages or software bugs can lead to data becoming deleted or inaccessible. Having a robust backup and recovery strategy can help mitigate the consequences of such an occurrence. A good rule for backups is the 3-2-1 strategy:

- Three copies of the data
- Two different types of media for backup storage

- One backup stored off-site (or in the cloud)

However, there are other configurations that need to be considered when implementing a backup strategy. For example, attackers should never gain access to backup data or administrative backup accounts.

Common Attack Vectors

This section describes common attacks on backup infrastructure.

Ransomware

Ransomware describes a family of malware that is primarily used to encrypt data and extort money by selling the decryption key for a high price. The more data that is encrypted and unrecoverable, the higher the chances of a target company paying the ransom. The only effective way of dealing with a ransomware incident that has already happened is to have backups ready for deployment. This however only works if an attacker was not able to already compromise the backup infrastructure and delete files there.

Backup Compromise

Since backups are the last line of defense against Ransomware, attackers that gain foothold into a network will try to compromise all possible backups they find. Backups also contain sensitive information that can be used for lateral movement or exploitation (e.g. passwords, machine account hashes etc.), which makes it a prime target for attackers. In this context, compromise usually means altering retention policies. This involves silently deleting old backups, ensuring that new ones are not stored correctly and corrupting existing data.

Separating backup infrastructure from productive infrastructure such as the main Active Directory Domain and network is therefore very important for maintaining security. This means, that all backup servers have to be disconnected from the productive domain, and not be contained in neither tier of the [Active Directory Tiering Model](#). Additionally, [Network Segmentation](#) needs to be implemented for correctly separating backup infrastructure from productive infrastructure. Lastly, different accounts with [unique passwords](#) have to be used for administrating the backup infrastructure.

Attack Scenario

This section should demonstrate what can happen if the backup infrastructure is not properly secured. The setup of this attack scenario is as follows:

- [Network Segmentation](#) is not properly configured
- The attacker has already compromised a domain administrator account

- The attacker has no considerations regarding OPSEC, the most straightforward approach is used

Since the attackers already have a domain administrator account, they can login to the domain controller and enumerate all users and computers. The first step is to find out where backups are stored and who can access them. When browsing the domain users, the account `backupUser@lab.local` was found:

Name	Type	Description
Administrator	User	Built-in account for ad...
Allowed RODC Password Replic...	Security Group...	Members in this group c...
Backup	Security Group...	
backupUser	User	User to Backup Systems
Cert Publishers	Security Group...	Members of this group ...
clientuser1	User	

Additionally, a system named `openmediavault.lab.local` was found as a domain joined computer:

Name	Type	Description
Client3	Computer	
Client4	Computer	
FILESRV1	Computer	
OPENMEDIAVAULT	Computer	Backup Server
SRV3	Computer	

OpenMediaVault is a popular open-source NAS operating system, which is often used for backups. When checking the available SMB shares on this system, a share named `BackupShare` was found:

```
PS C:\Users\Administrator> net view \\openmediavault.lab.local /all
Shared resources at \\openmediavault.lab.local

openmediavault server

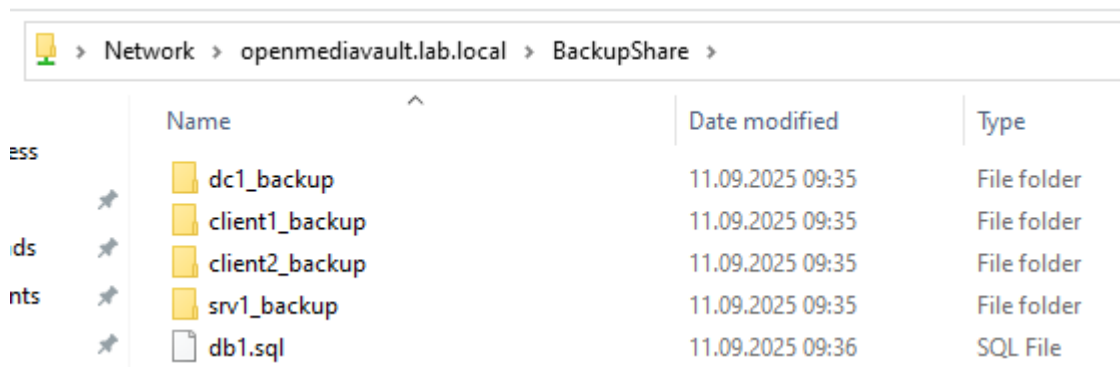
Share name   Type   Used as   Comment
-----
BackupShare  Disk   (UNC)
IPC$         IPC    IPC Service (openmediavault server)
The command completed successfully.
```

Because probably only the `backupUser@lab.local` account has access to this share, the attacker now needs to change the password of this account to easily impersonate it. This can be done with **PowerShell**:

```
Administrator: Windows PowerShell
PS C:\Users\Administrator> net user backupUser NewPWD!
The command completed successfully.

PS C:\Users\Administrator> _
```

After changing the password, the attacker can now access the backup share, delete all files and encrypt every system afterwards with ransomware:



	Name	Date modified	Type
ess	dc1_backup	11.09.2025 09:35	File folder
	client1_backup	11.09.2025 09:35	File folder
ds	client2_backup	11.09.2025 09:35	File folder
nts	srv1_backup	11.09.2025 09:35	File folder
	db1.sql	11.09.2025 09:36	SQL File

Mitigation

When the above-mentioned security controls are implemented, the attack would have been mitigated in the following ways:

- The attacker would not have been able to easily locate the backup server, because it would not have been joined to the Active Directory domain.
- Even if the attacker had discovered the backup server, access to the backup share would have been blocked through [network segmentation](#) and ACLs.
- The attacker would not have been able to change the password of the backup user, since separate accounts would have been used for administrating the backup infrastructure.
- The attacker would not have been able to delete backup files, since retention policies would have been correctly configured.
- The attacker would not have been able to effectively encrypt all systems, since alternative backups would have remained available for data restoration.